Практическое занятие № 4

ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения»

Тема: Разработка технического проекта системы защиты информации объекта информатизации.

Цели практического занятия:

– изучение нормативных правовых актов и методических документов, регламентирующих порядок и правила разработки технического проекта системы защиты информации (СЗИ) объекта информатизации;

– формирование практических навыков анализа исходных данных об объекте информатизации и определения проектных решений по СЗИ;

– выработка навыка разработки технического проекта СЗИ в соответствии с установленными требованиями.

Время - 6 часов.

Материально-техническое обеспечение.

Работа выполняется на ПЭВМ типа IBM PC с использованием стандартных функций ОС и дополнительных пакетов программ (Adobe Acrobat Reader ver. 3.0 или выше, либо аналогичные программы для просмотра файлов с расширением pdf).

Используемые нормативные правовые акты

1. Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации».
2. Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных».
3. Федеральный закон от 29.07.2004 № 98-ФЗ «О коммерческой тайне».
4. Постановление Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных».
5. Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» (с изменениями).
6. Методический документ ФСТЭК России «Методика оценки угроз безопасности информации» от 05.02.2021.
7. Руководящий документ Гостехкомиссии России от 30.03.1992 «Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации».
8. Приказ ФСТЭК России от 29.04.2021 № 77 «Об утверждении Порядка

организации и проведения работ по аттестации объектов информатизации на соответствие требованиям о защите информации ограниченного доступа, не составляющей государственную тайну».

9. Специальные требования и рекомендации по технической защите конфиденциальной информации (СТР-К), утвержденные приказом Гостехкомиссии России от 30.08.2002 № 282.

10. ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения».

11. ГОСТ Р 51624-2000 «Защита информации. Автоматизированные системы в защищенном исполнении. Общие требования».

12. ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы».

1 Методические указания студентам по подготовке и проведению практического занятия

1.1 При подготовке к занятию

В период подготовки к практическому занятию студенты получают необходимую литературу в библиотеке университета или из открытых источников сети Интернет и изучают учебные материалы темы, используя литературу, а также конспект лекций. При подготовке к занятию уточнить содержание источников (литературы), рекомендуемой к данному занятию (пособия и учебники со сроком издания не более 5 лет). В ходе изучения материала на практическом занятии студентам рекомендуется ответить на контрольные вопросы, указанные в лекции и в методических рекомендациях по практическому занятию.

1.2 Порядок проведения занятия

Занятие разбивается на два блока по 3 часа каждый.

В первом блоке практического занятия (3 часа) студенты последовательно усваивают учебные вопросы, касающиеся ГОСТ Р 51583-2014, лично отрабатывают контрольные вопросы практического занятия. При необходимости сложные и малопонятные вопросы обсуждаются в группе под руководством преподавателя.

Во втором блоке практического занятия (3 часа) студенты изучают теоретические сведения, нормативные правовые акты и методические документы, касающиеся разработки технического проекта системы защиты информации объекта информатизации.

Далее, необходимо ознакомиться с рекомендуемой структурой и содержанием разделов технического проекта СЗИ.

Используя шаблон (Приложение 2) и исходные данные (раздел 3) для выполнения практического задания:

- разработать разделы технического проекта в соответствии со структурой;

- обосновать выбор организационных и технических мер защиты информации;

- выбрать конкретные сертифицированные СЗИ из реестра ФСТЭК России в соответствии с моделью угроз;

- разработать схему размещения СЗИ;

- оформить технический проект системы защиты информации объекта информатизации в виде документа с титульным листом (включающим грифы утверждения и согласования), разделами в соответствии с рекомендуемой структурой и листом согласования.

Примечание:

В качестве исходных данных при проектировании системы защиты объекта информатизации студентами могут использоваться как исходные данные, представленные в методическом пособии, так и автоматизированные системы из лабораторных/практических работ по дисциплине «Защита информации от утечки по техническим каналам».

По окончании занятия студенты оформляют отчет и представляют его преподавателю.

1 Краткие теоретические сведения

Технический проект является стадией создания автоматизированной системы в защищенном исполнении, на которой разрабатываются и утверждаются проектные решения по системе защиты информации. В соответствии с ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения» разработка (проектирование) системы защиты информации включает: разработку проектных решений по системе ЗИ АСЗИ; разработку документации на систему ЗИ АСЗИ; тестирование системы ЗИ АСЗИ.

Разработку системы защиты информации организует заказчик, проводит разработчик в соответствии с техническим заданием на создание системы ЗИ АСЗИ на следующих стадиях создания АСЗИ, определенных ГОСТ 34.601: Эскизный проект, Технический проект, Рабочая документация.

На стадии **«Технический проект»** в интересах создания системы защиты информации выполняют следующие работы:

- на этапе «Разработка проектных решений по системе и ее частям» обеспечивают: разработку общих решений по системе ЗИ, по ее функциональной структуре, техническим и программным средствам системы ЗИ; разработку макетов составных частей системы ЗИ (при необходимости);

- на этапе «Разработка документации на АС и ее части» проводят разработку, оформление, согласование и утверждение технической документации на систему ЗИ;

- на этапе «Разработка и оформление документации на поставку изделий для комплектования АС и (или) технических требований (технических заданий)

на их разработку» проводят: подготовку и оформление документов на поставку технических и программных средств для комплектования системы ЗИ создаваемой (модернизируемой) АСЗИ; определение требований к оборудованию и материалам, изготавливаемым серийно;

- на этапе «Разработка заданий на проектирование в смежных частях проекта объекта информатизации» осуществляют разработку, оформление, согласование и утверждение заданий на проектирование помещений для АСЗИ с учетом требований о защите информации.

На стадии **«Рабочая документация»** в интересах создания системы защиты информации проводят разработку рабочей документации на систему ЗИ, содержащей все необходимые сведения для монтажа, наладки и эксплуатации системы защиты информации.

В соответствии с «Специальными требованиями и рекомендациями по технической защите конфиденциальной информации (СТР-К)» (утв. приказом Гостехкомиссии России от 30.08.2002 № 282) на стадии проектирования и создания объекта информатизации оформляются также технический (технорабочий) проект и эксплуатационная документация СЗИ, состоящие из:

- пояснительной записки с изложением решений по комплексу организационных мер и программно-техническим (в том числе криптографическим) средствам обеспечения безопасности информации, состава средств защиты информации с указанием их соответствия требованиям ТЗ;
- описания технического, программного, информационного обеспечения и технологии обработки (передачи) информации;
- плана организационно-технических мероприятий по подготовке объекта информатизации к внедрению средств и мер защиты информации;
- технического паспорта объекта информатизации (форма технического паспорта на АС приведена в приложении № 5);

инструкций и руководств по эксплуатации технических и программных средств защиты для пользователей, администраторов системы, а также для работников службы защиты информации.

2 Перечень задач, решаемых при разработке технического проекта СЗИ

– Разработка общих решений по системе защиты информации, ее функциональной структуре, техническим и программным средствам.

– Определение состава и содержания организационных и технических мер защиты информации на основе требований нормативных документов.

– Разработка схем размещения средств защиты информации и их подключения к защищаемому объекту.

– Определение политик безопасности: правил разграничения доступа, списков контроля доступа (ACL), правил фильтрации трафика, настроек аудита.

– Разработка технической документации на систему защиты информации (пояснительная записка, схемы, спецификации, ведомости).

– Подготовка заданий на проектирование смежных частей проекта

объекта информатизации (помещения, инженерные системы).

– Оформление документации на поставку технических и программных средств для комплектования СЗИ.

– Определение требований к эксплуатации системы защиты информации и подготовке персонала.

3 Исходные данные для разработки технического проекта на создание СЗИ

Информационная система персональных данных «Кадровый учет»

Описание информационной системы персональных данных организации ИСПДн «Кадровый учет»:

Организация: АО УК «Чистый дом», организация осуществляет деятельность по управлению многоквартирными домами, предоставлению жилищно-коммунальных услуг и иные виды деятельности, связанные с эксплуатацией жилищного фонда.

Описание ИСПДн:

Состав:

Персональные данные сотрудников организации:

- фамилия, имя, отчество;
- дата и место рождения;
- пол;
- сведения об образовании;
- сведения о предыдущем месте работы;
- адреса регистрации и фактического проживания;
- номера контактных телефонов;
- индивидуальный номер налогоплательщика;
- номер страхового свидетельства пенсионного страхования;
- номер полиса обязательного медицинского страхования;
- данные водительского удостоверения.

В информационной системе одновременно обрабатываются данные 98 субъектов персональных данных (сотрудников) в пределах Организации.

2. Имеется три автоматизированных рабочих места (АРМ) пользователей, сетевой принтер, сервер, коммутационное оборудование.

Топология: АРМ и сервер составляют сегмент корпоративной вычислительной сети (см. схему).

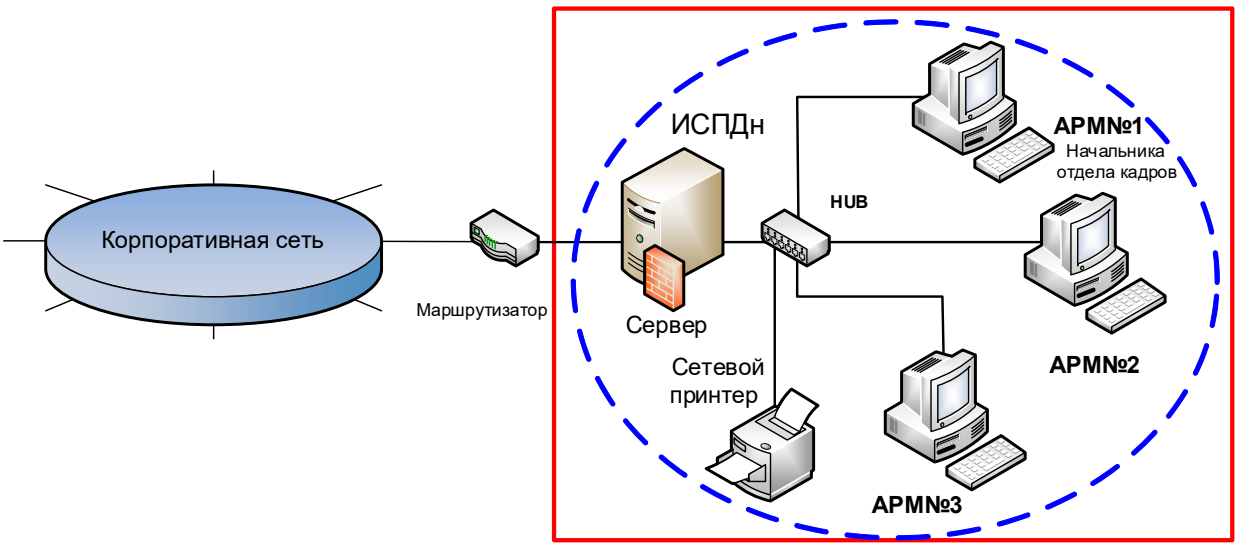


Схема ИСПД АО УК «Чистый дом»

Корпоративная сеть Организации не имеет подключение к сетям связи общего пользования и сетям международного информационного обмена.

В состав каждого АРМ входят два жёстких диска, на первом установлена операционная система, прикладное программное обеспечение и общедоступная справочная информация, на втором - информация, составляющая персональные данные сотрудников Организации.

1. Комплект АРМ № 1-3 (см. схему):
   - системный блок CityTime № JFBNCGRHDBG01-03,
   - монитор Samsung N710 – серийный номер KBMHDFGFD01-03,
   - клавиатура Genius серийный номер WESDC01-03,
   - графический манипулятор (мышь) Genius серийный номер DSDA01-03.

Состав ПО для обработки ПД:

- Клиентская часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».

- Диспетчер печати.

2. В состав сервера входят три жестких диска, на первом установлена операционная система, прикладное программное обеспечение, второй и третий объединены в RAID массив, в котором хранится информация, составляющая персональные данные сотрудников Организации.

Комплект сервера:
   - системный блок CityTime Prof № SDHBKYDHG04,
   - монитор Samsung N710 – серийный номер JDHDNGHD04,
   - клавиатура Genius серийный номер DGFU04,
   - графический манипулятор Genius серийный номер HBDR04.

Состав ПО для обработки ПД:

- Серверная часть ПО «1С:Зарплата и кадры 8» хранит информацию о сотрудниках, кандидатах и соискателях (в версии КОРП) в соответствии с требованиями Федерального закона от 27.07.2006 № 152-ФЗ «О персональных данных».
2. Диспетчер печати.

Сервер и коммуникационное оборудование установлены в типовой стойке.
Сетевой принтер HP LaserJet P2015 серийный номер DEFVBG.
Коммутатор: Коммутатор Cisco WS-C2960CX-8TC-L.
Маршрутизатор: Маршрутизатор Cisco Small Business RV340-K8-RU.

1. Технология обработки персональных данных:

Обработка персональных данных сотрудников включает весь перечень действий, включая сбор, запись, систематизацию, накопление, хранение, уточнение (обновление, изменение), извлечение, использование, передачу (распространение, предоставление, доступ), обезличивание, блокирование, удаление, уничтожение персональных данных.

К работе на АРМ допущены сотрудники отдела кадров и заместитель директора.

Полный доступ ко всей информации на АРМ и сервере имеют заместитель директора и начальник отдела кадров.

Сотрудники отдела кадров имеют полный доступ только к каталогу «Личные дела», размещённой на диске №2 своего АРМ, и только на чтение информации из каталога «Личные дела» на сервере.

Системный администратор сегмента сети не имеет доступа к информации, составляющей персональные данные. Имеет права на инсталляцию, настройку программного обеспечения, программных (программно-аппаратных) средств защиты сервера и АРМ № 1-3.

Режим работы - одновременный.

Расположение: АО УК «Чистый дом», г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306, расположено на третьем этаже 3-х этажного здания. На 1-ом и 2-ем этажах расположены сторонние организации. Имеется общая охраняемая территория. Допуск посторонних лиц и автомашин только с согласия руководителя Организации и руководителей сторонних организаций. Доступ в помещение ограничен распорядительными актами Организации и автоматизированной системой контроля и управления доступа. Перечень сотрудников, имеющих доступ к конфиденциальной информации, определен приказом руководителя АО УК «Чистый дом».

Контролируемая зона (КЗ) ЗП для носимых ТСР проходит по ограждающим конструкциям третьего этажа, за исключением лестницы на верхние этажи. Исследуемое ЗП - переговорная – не граничит с КЗ для возимых ТСР, а для носимых ТСР граничит по потолку. КЗ для возимых ТСР проходит по периметру внешнего ограждения (забора) организации. Границей КЗ для стационарных ТСР является: с севера – жилое здание (расстояние 250 м.), с юга

- территория организации ООО «Интеко» (расстояние 189 м.), с запада – здание бассейна «Волна» (расстояние 176 м.), с востока - жилое здание, находящееся через парк (расстояние 1020 м.). Средства звукоусиления отсутствуют.

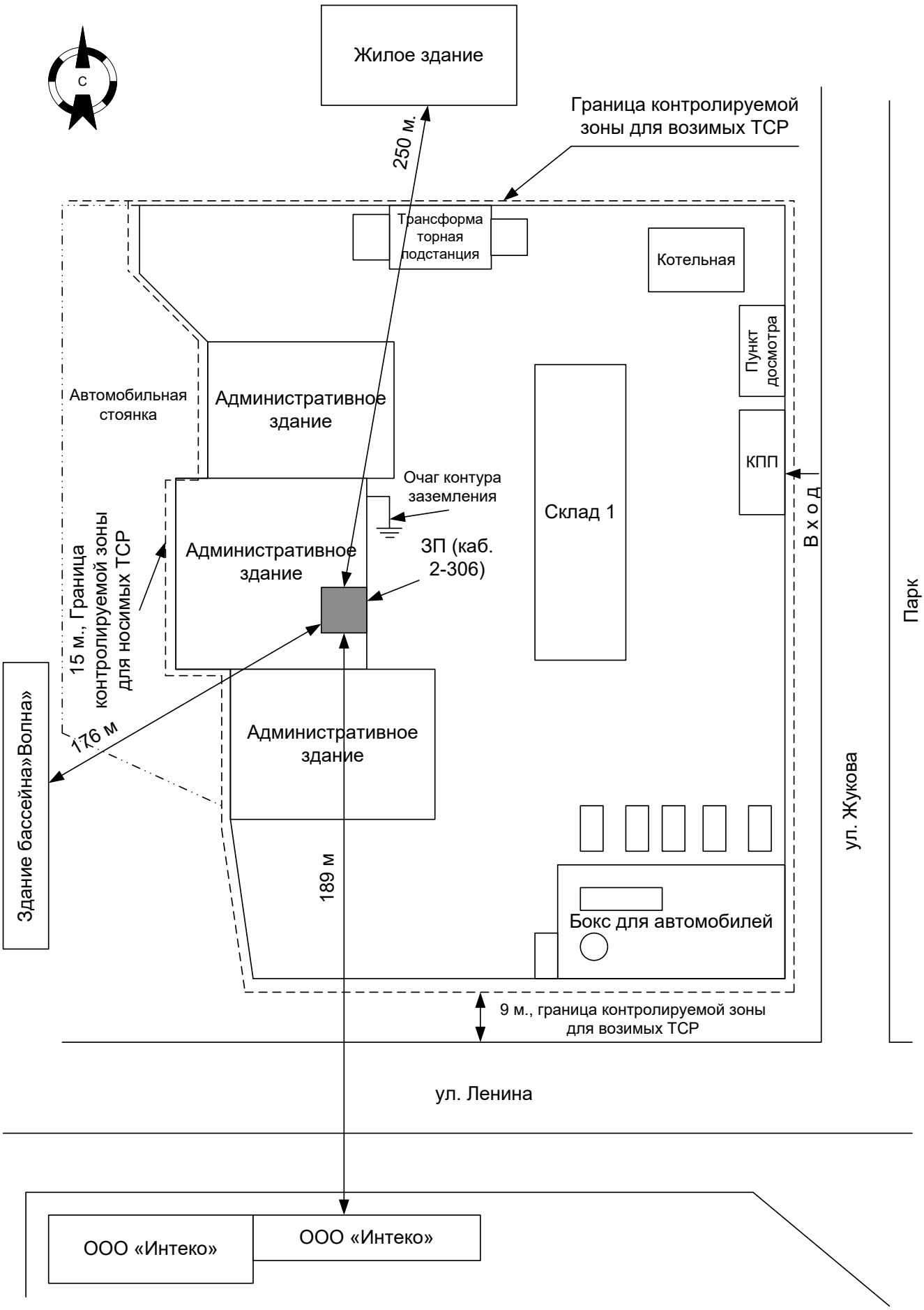


Схема границ контролируемых зон АО УК «Чистый дом»

4 Разработка технического проекта системы защиты информации

Рекомендуемая структура и содержание технического проекта СЗИ

Рекомендуемая структура технического проекта на создание СЗИ приведена в таблице 1.

Таблица 1 – Рекомендуемая структура технического проекта СЗИ

№ раздела	Наименование раздела	Краткое содержание
1	Общие положения	Наименование системы защиты информации, наименование организаций заказчика и разработчика, основание для проведения работ, назначение и цели системы защиты информации АС, нормативно-правовая база для проведения работ, сведения об использованных при проектировании документах
2	Характеристика объекта защиты	Общее описание объекта защиты, функциональные характеристики АС, перечень обрабатываемой информации, описание ИТ-инфраструктуры, категории данных, обрабатываемых в АС, классификация объекта информатизации, информация о пользователях
3	Основные технические решения	Структура и функциональный состав системы защиты информации АС, виды и типы средств защиты информации, обеспечивающие реализацию технических мер по защите информации в АС: • Общий состав средств защиты информации • Средства защиты информации от несанкционированного доступа • Средства антивирусной защиты • Средства межсетевого экранирования • Средства защиты каналов связи • Средства защиты среды виртуализации • Система обнаружения вторжений • Средства анализа защищенности • Места размещения элементов системы защиты информации Системы Также указываются меры защиты информации,

		подлежащие реализации в системе защиты информации Ас, и их выполнение, реализация мер по нейтрализации актуальных угроз безопасности информации, сертификаты соответствия требованиям безопасности информации применяемых средств защиты информации, решение по: • организационному обеспечению • численности и квалификации персонала системы защиты информации. Описывается обеспечение надежности и безопасности, решения по эксплуатации, техническому обслуживанию, ремонту и хранению компонентов и обеспечение сохранности информации при авариях
4	Мероприятия по подготовке к внедрению системы защиты информации	Описываются организационные меры по обеспечению безопасности АС и перечень локальных актов, разрабатываемых на этапе внедрения системы защиты информации

5 Вопросы для самоконтроля

7.1 Что такое технический проект системы защиты информации и в чем его отличие от технического задания?

7.2 Какими нормативными документами регламентируется порядок разработки технического проекта СЗИ?

7.3 Какие основные работы выполняются на стадии «Технический проект» в соответствии с ГОСТ Р 51583-2014?

7.4 Какие разделы рекомендуется включать в технический проект СЗИ?

7.5 Как определить перечень мер защиты для ИСПДн с 4 уровнем защищенности?

7.6 Какие сертифицированные средства защиты информации могут быть предложены для защиты от НСД в ИСПДн «Кадровый учет»?

6 Литература

6.1 Нормативные правовые акты

6.1.1 Федеральный закон от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации»

6.1.2 Федеральный закон от 27.07.2006 № 152-ФЗ «О персональных данных»

6.1.3 Федеральный закон от 29.07.2004 № 98-ФЗ «О коммерческой тайне»

6.1.4 Постановление Правительства РФ от 01.11.2012 № 1119 «Об утверждении требований к защите персональных данных при их обработке в

информационных системах персональных данных».

6.1.5 Приказ ФСТЭК России от 18.02.2013 № 21 «Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных» (с изменениями).

6.1.6 Руководящий документ «Автоматизированные системы. Защита от несанкционированного доступа к информации. Классификация автоматизированных систем и требования по защите информации» (утв. решением Государственной технической комиссии при Президенте РФ от 30 марта 1992 г.).

6.1.7 Методический документ ФСТЭК России «Методика оценки угроз безопасности информации» от 05.02.2021.

6.1.8 Специальные требования и рекомендации по технической защите конфиденциальной информации (СТР-К), утвержденные приказом Гостехкомиссии России от 30.08.2002 № 282.

6.1.9 ГОСТ Р 51583-2014 «Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения».

6.1.10 ГОСТ Р 51624-2000 «Защита информации. Автоматизированные системы в защищенном исполнении. Общие требования».

6.1.11 ГОСТ Р 51275-2006 «Защита информации. Объект информатизации. Факторы, воздействующие на информацию. Общие положения».

6.1.12 ГОСТ 34.602-2020 «Информационные технологии. Комплекс стандартов на автоматизированные системы. Техническое задание на создание автоматизированной системы».

6.1.13 Приказ ФСТЭК России от 29.04.2021 № 77 «Об утверждении Порядка организации и проведения работ по аттестации объектов информатизации на соответствие требованиям о защите информации ограниченного доступа, не составляющей государственную тайну»

6.2 Учебная и методическая литература

6.2.1 Информационная безопасность. Техническая защита конфиденциальной информации : учебное пособие / Говядкин Н.В., Кислов Р.И., Лепешкин О.М., Лысов А.В. – СПб: Медиапапир, 2019. – 466 с.

6.2.2 Шаньгин В.Ф. Комплексная защита информации в корпоративных системах : учебное пособие для вузов. – М.: ФОРУМ : ИНФРА-М, 2012. – 592 с.

6.2.3 Хорев А.А. Техническая защита информации : учеб. пособие для студентов вузов. В 3 т. Т. 1. Технические каналы утечки информации. – М.: НПЦ «Аналитика», 2010. – 436 с.

6.3 Электронные ресурсы

6.3.1 Официальный сайт Федеральной службы по техническому и экспортному контролю (ФСТЭК России) – www.fstec.ru.

6.3.2 Банк данных угроз безопасности информации ФСТЭК России – www.bdu.fstec.ru.

6.3.3 Официальный интернет-портал правовой информации – http://publication.pravo.gov.ru

Приложение 1
Шаблон технического проекта на создание системы защиты информации

УТВЕРЖДАЮ[1]

_____
(должность руководителя организации)

_____
(подпись)
«_____» _____ 202 ____г.

ОБЪЕКТ ИНФОРМАТИЗАЦИИ
«ИНФОРМАЦИОННАЯ СИСТЕМА ОБРАБОТКИ ПЕРСОНАЛЬНЫХ ДАННЫХ «КАДРОВЫЙ УЧЕТ» АКЦИОНЕРНОГО ОБЩЕСТВА «УПРАВЛЯЮЩАЯ КОМПАНИЯ «ЧИСТЫЙ ДОМ»»

ПОЯСНИТЕЛЬНАЯ ЗАПИСКА К ТЕХНИЧЕСКОМУ ПРОЕКТУ
на создание системы защиты информации

202_ г.

[1] Техническое (частное техническое) задание на разработку СЗИ подписывается разработчиком, согласовывается со службой безопасности предприятия-заказчика, подрядными организациями и утверждается заказчиком. Перечень сведений конфиденциального характера составляется заказчиком объекта информатизации и утверждается его руководителем.

Перечень сокращений

АВЗ	–	антивирусная защита
АНЗ	–	контроль (анализ) защищенности информации
АПКШ	–	аппаратно-программный комплекс шифрования
АРМ	–	автоматизированное рабочее место
АУД	–	аудит безопасности
ГИС	–	государственная информационная система
ЗИС	–	защита информационной системы и ее компонентов
ЗНИ	–	защита машинных носителей информации
ЗСВ	–	защита среды виртуализации
ЗТС	–	защита технических средств и систем
ИАФ	–	идентификация и аутентификация
ИНЦ	–	реагирование на инциденты информационной безопасности
ИОД	–	информация ограниченного доступа (включая персональные данные), не содержащая сведения, составляющие государственную тайну
ИС	–	информационная система
ИСПДн	–	информационная система персональных данных
КЗ	–	контролируемая зона
КШ	–	комплекс шифрования
МЭ	–	межсетевой экран
НСД	–	несанкционированный доступ
ОС	–	операционная система
ПДн	–	персональные данные
ПО	–	программное обеспечение
САВЗ	–	средство антивирусной защиты
САЗ	–	средство анализа защищенности
СВТ	–	средство вычислительной техники
СЗИ	–	подсистема безопасности (система защиты информации)
СКЗИ	–	средство криптографической защиты информации
СОВ	–	обнаружение (предотвращение) вторжений
СрЗИ	–	средство защиты информации
УБИ	–	угроза безопасности информации
УКФ	–	управление конфигурацией информационной системы
УПД	–	управление доступом
ФСБ России	–	Федеральная служба безопасности Российской Федерации
ФСТЭК России	–	Федеральная служба по техническому и экспортному контролю

Содержание

1. Общие положения ..... **Ошибка! Закладка не определена.**
1.1. Наименование системы защиты информации ..... **Ошибка! Закладка не определена.**
1.2. Наименование организаций заказчика и разработчика **Ошибка! Закладка не определена.**
1.3. Основание для проведения работ ..... **Ошибка! Закладка не определена.**
1.4. Назначение и цели системы защиты информации Системы **Ошибка! Закладка не определена.**
1.5. Нормативно-правовая база для проведения работ 16
1.6. Сведения об использованных при проектировании документах 17
2. Характеристика объекта защиты 18
2.1. Общее описание 18
2.2. Функциональные характеристики Системы 18
2.3. Перечень обрабатываемой информации 18
2.4. Описание ИТ-инфраструктуры 18
2.5. Категории данных, обрабатываемых в Системе 19
2.6. Классификация объекта информатизации 19
2.7. Информация о пользователях 20
3. Основные технические решения 21
3.1. Структура и функциональный состав системы защиты информации Системы 21
3.2. Виды и типы средств защиты информации, обеспечивающие реализацию технических мер по защите информации в Системе 21
3.2.1. Общий состав средств защиты информации 22
3.2.2. Средства защиты информации от несанкционированного доступа 22
3.2.3. Средства антивирусной защиты 22
3.2.4. Средства межсетевого экранирования 22
3.2.5. Средства защиты каналов связи 23
3.2.6. Средства защиты среды виртуализации ..... **Ошибка! Закладка не определена.**
3.2.7. Система обнаружения вторжений 23
3.2.8. Средства анализа защищенности 24
3.2.9. Места размещения элементов системы защиты информации Системы 24
3.3. Меры защиты информации, подлежащие реализации в системе защиты информации Системы, и их выполнение 24
3.4. Реализация мер по нейтрализации актуальных угроз безопасности информации 28
3.5. Сертификаты соответствия требованиям безопасности информации применяемых средств защиты информации 29
3.6. Решение по организационному обеспечению 30
3.7. Решение по численности и квалификации персонала системы защиты информации 30
3.8. Обеспечение надежности 31
3.9. Обеспечение безопасности 31
3.10. Решения по эксплуатации, техническому обслуживанию, ремонту и хранению компонентов 31
3.11. Обеспечение сохранности информации при авариях 32
4. Мероприятия по подготовке к внедрению системы защиты информации 33
Приложение № 1 34

Приложение № 2 35

1 Общие сведения

1.1 Полное наименование объекта информатизации и его условное обозначение

Полное наименование системы: *«Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом»»*[2]

Краткое наименование: *СЗИ Системы.*

1.2 Наименование организации-заказчика объекта информатизации, наименование организации-разработчика, наименование Оператора объекта информатизации

Разработчик: *Закрытое акционерное общество «Центр безопасности информационных технологий» (ЗАО «ЦБИТ»)*

Юридический адрес: *г. Ростов-на-Дону, ул. Ростовская, д. 16.*

Заказчик, Оператор Системы: *акционерное общество «Управляющая компания «Чистый дом»»*

Юридический адрес: *344000, г. Ростов-на-Дону, ул. Строителей, дом № 15, офис 306.*

1.3 Основание для выполнения работ

Основанием для выполнения работ является договор № 655433-Д от 31.01.2025.

1.4 Назначение и цели системы защиты информации Системы

СЗИ Системы должна обеспечивать комплексную защиту обрабатываемой в Системе ИОД.

Целями создания СЗИ Системы является реализация перечня необходимых мероприятий по обеспечению безопасности информации Системы посредством предупреждения и предотвращения несанкционированного доступа к ней в соответствии с требованиями действующего законодательства Российской Федерации, нормативных правовых актов в области защиты информации.

Реализуемая СЗИ Системы должна обеспечивать доступность, целостность и конфиденциальность защищаемой ИОД в процессе ее обработки, хранения и передачи.

Организационные и технические меры защиты информации, реализуемые СЗИ Системы должны быть направлены на исключение:

- *неправомерного доступа, копирования, предоставления или распространения информации (обеспечение конфиденциальности информации);*
- *неправомерного уничтожения или модифицирования информации (обеспечение целостности информации);*
- *неправомерного блокирования информации (обеспечение доступности информации).*

1.5 Нормативно-правовая база для проведения работ

Федеральный закон от 27.07.2006 № 149-ФЗ "Об информации, информационных технологиях и о защите информации".

[2] Здесь и далее по тексту шаблона ТП курсивом приведено возможное наполнение соответствующего раздела (подраздела) ТП

Федеральный закон от 27.07.2006 № 152-ФЗ "О персональных данных".

Указ Президента Российской Федерации от 06.03.1997 № 188 "Об утверждении Перечня сведений конфиденциального характера".

Постановление Правительства Российской Федерации от 01.11.2012 № 1119 "Об утверждении требований к защите персональных данных при их обработке в информационных системах персональных данных".

Приказ ФСТЭК России от 13.02.2013 № 21 "Об утверждении состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных" (далее – приказ ФСТЭК России № 21).

Приказ ФСБ России от 10.07.2017 № 378 "Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности персональных данных при их обработке в информационных системах персональных данных с использованием средств криптографической защиты информации, необходимых для выполнения установленных Правительством Российской Федерации требований к защите персональных данных для каждого из уровней защищенности".

Методический документ "Меры защиты информации в государственных информационных системах", утвержденный ФСТЭК России 11 февраля 2014 г.

ГОСТ 59853-2021 " Информационные технологии. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Термины и определения ".

ГОСТ 34.201-20 "Информационная технология. Комплекс стандартов на автоматизированные системы. Виды, комплектность и обозначение документов при создании автоматизированных систем".

ГОСТ 34.601-90 "Информационная технология. Комплекс стандартов на автоматизированные системы. Автоматизированные системы. Стадии создания".

ГОСТ 59.792-21 "Информационная технология. Виды испытаний автоматизированных систем".

ГОСТ Р 51583-2014 "Защита информации. Порядок создания автоматизированных систем в защищенном исполнении. Общие положения".

1.6 Сведения об использованных при проектировании документах

Модель угроз безопасности информации объекта информатизации Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом» (далее – Модель угроз).

Объект информатизации Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом». Техническое задание на создание системы защиты информации (далее – Техническое задание).

2. Характеристика объекта защиты

2.1. Общее описание

Полное наименование – *объект информатизации «Информационная система обработки персональных данных «Кадровый учет» акционерного общества «Управляющая компания «Чистый дом»».*

Условное обозначение: *Система.*

Назначение Системы: *Система предназначена для обработки персональных данных сотрудников АО УК «Чистый дом».*

Пользователи: *работники АО УК «Чистый дом».*

Эксплуатационный персонал (сопровождение Системы): *работники АО УК «Чистый дом».*

Адрес расположения объекта информатизации *344000, г. Ростов-на-Дону, ул. Строителей, д. № 1.*

2.2. Функциональные характеристики Системы

Система включает в себя следующие ИС:

– 1С:Зарплата и кадры 8.

2.3. Перечень обрабатываемой информации

В Системе планируется обработка общедоступной информации и ИОД, не содержащей сведения, составляющие государственную тайну, включая ПДн.

В Системе обрабатывается следующая ИОД, включая ПДн:

- *фамилия, имя, отчество;*
- *дата и место рождения;*
- *пол;*
- *сведения об образовании;*
- *сведения о предыдущем месте работы;*
- *адреса регистрации и фактического проживания;*
- *номера контактных телефонов;*
- *индивидуальный номер налогоплательщика;*
- *номер страхового свидетельства пенсионного страхования;*
- *номер полиса обязательного медицинского страхования;*
- *данные водительского удостоверения.*

Полный перечень обрабатываемых в системе ПДн определен в Положении о порядке обработки и защите ПДн

2.4. Описание ИТ-инфраструктуры

Система представляет собой совокупность серверного оборудования, АРМ, сетевого оборудования, а также общего и прикладного ПО, реализующего функции по обработке информации.

Компоненты системы располагаются по следующему адресу:

– г. Ростов-на-Дону, ул. Строителей, дом № 1;

Система не имеет подключение к сети международного обмена "Интернет".

– Система не осуществляет взаимодействие с ГИС

АРМ пользователей представляют собой физические рабочие места следующего вида:

1) Стационарный персональный компьютер в составе:

- *системный блок;*
- *монитор;*
- *клавиатура;*
- *манипулятор "Мышь".*

В состав технических средств Системы будет входить:

- *сервер;*
- *АРМ пользователей;*
- *активное и пассивное сетевое оборудование;*
- *устройства печати (многофункциональное устройство, принтер);*
- *программно-аппаратные СрЗИ.*

Информация о перечне и типах (ролях) сервера с указанием места размещения сервера и рабочих станций представлена в таблицах №№ 1 и 2 соответственно.

Таблица 1 – Информация о серверном оборудовании

№ п/п	*Тип сервера*	*Роль*	*Место размещения*	*IP-адрес*
1.	*Физический*	*1С:Зарплата и кадры 8*	*г. Ростов-на-Дону, ул. Строителей, д. № 1*	*192.168.0.1*

Таблица 2 – Информация о типовых рабочих станциях

№ п/п	*Тип*	*Тип ОС*	*Роль*	*Количество*
1.	*Физический*	*MS Windows*	*АРМ пользователя*	*3*

Парк коммутационного оборудования состоит из набора как управляемых, так и неуправляемых коммутаторов Cisco, в промышленном и домашнем исполнениях. Включение коммутационного оборудование в информационную инфраструктуру выполнено каскадным методом.

В составе сетевой инфраструктуры отсутствуют Wi-Fi точки доступа.

2.5. Категории данных, обрабатываемых в Системе

При функционировании в Системе будет производиться обработка открытой информации и ИОД, не содержащей сведений, составляющих государственную тайну.

Защищаемой информацией в Системе являются:

- *ПДн;*
- *конфиденциальная информация;*
- *ключевая, аутентифицирующая и парольная информация;*
- *информация о настройках и конфигурации Системы.*

Основными характеристиками безопасности информации в Системе являются конфиденциальность, целостность и доступность.

2.6. Классификация объекта информатизации

Согласно постановлению Правительства Российской Федерации от 01.11.2012 № 1119 "Об утверждении требований к защите персональных данных при их обработке

в информационных системах персональных данных", уровень защищенности ПДн, обрабатываемых в Системе, определяется исходя из категории и количества ПДн, а также актуальности угроз различных типов. Оценка данных характеристик относительно Системы приведена в таблице 4.

Таблица 4 – Характеристики Системы

Характеристика	*Значение*	*Примечание*
Субъекты ПДн	*более 100 000*	*являются сотрудниками Оператора*
Категории ПДн	*иные*	*Система не обрабатывает, биометрические, специальные и общедоступные категории ПДн*
Тип актуальных угроз	*третий*	*т.к. актуальны угрозы, не связанные с наличием недокументированных (недекларированных) возможностей в системном и прикладном ПО, используемом в Системе*

Таким образом, в Системе обусловлена необходимость обеспечения третьего уровня защищенности ПДн (УЗ3).

2.7. Информация о пользователях

Пользователи в Системе разделяются на категории, различающиеся правами доступа к информационно-функциональным ресурсам Системы (дискреционный и ролевой методы управления доступом).

Доступ к ресурсам Системы осуществляют следующие категории лиц (субъекты доступа):

- *администратор безопасности (работник АО УК «Чистый дом», ответственный за обеспечение безопасности информации);*
- *системный администратор (работник АО УК «Чистый дом», ответственный за функционирование ОС, общесистемного и прикладного ПО);*
- *пользователи Системы (внутренние) – работники АО УК «Чистый дом».*

3. Основные технические решения

3.1 Структура и функциональный состав системы защиты информации Системы

Объектами защиты в Системе являются:

- *ИОД, обрабатываемая в Системе, включая ПДн;*
- *программно-технические средства: сетевое оборудование, сервер, АРМ пользователей, АРМ администраторов;*
- *общесистемное и прикладное ПО;*
- *телекоммуникационное оборудование, в том числе ПО для управления телекоммуникационным оборудованием;*
- *каналы связи внутри и за пределами КЗ;*
- *помещения (серверные), в которых располагается комплекс программно-технических средств Системы;*
- *СрЗИ, в том числе СКЗИ, а также среда функционирования СКЗИ.*

Субъектами доступа в Системе являются:

- *пользователи Системы, определенные в п. 2.7 настоящего документа;*
- *процессы, запускаемые от имени пользователей;*
- *взаимодействующие ИС.*

В Системе будет применяться ролевой метод управления доступом. Типы доступа (чтение, запись, выполнение и (или) иные) перечисленных субъектов доступа к объектам доступа и правила доступа субъектов доступа к объектам доступа будут определены в разрешительной системе (матрице) доступа к информационным ресурсам, программным и техническим средствам Системы при разработке эксплуатационной документации на СЗИ.

СЗИ Системы будет включать в себя комплекс технических и организационных мер защиты информации.

СЗИ Системы будет реализовывать следующие организационные и технические меры защиты информации:

- *идентификация и аутентификация;*
- *управление доступом;*
- *защита машинных носителей информации;*
- *регистрация событий безопасности;*
- *антивирусная защита;*
- *обнаружение вторжений;*
- *контроль (анализ) защищенности информации;*
- *защита среды виртуализации;*
- *защита технических средств и систем;*
- *защита ИС, ее средств, систем связи и передачи данных;*
- *управление конфигурацией.*

Перечисленные меры защиты информации Системы будут реализованы с применением сертифицированных СрЗИ, в том числе СКЗИ.

3.2 Виды и типы средств защиты информации, обеспечивающие реализацию технических мер по защите информации в Системе

В соответствии с приказом ФСТЭК России № 21 в ИСПДн 3 уровня защищенности ПДн применяются СрЗИ 6 класса защиты и 6 уровня доверия, а также СВТ не ниже 5 класса.

Выбор СрЗИ был осуществлен с учетом обязательного наличия сертификатов соответствия требованиям по безопасности информации, стоимости СрЗИ, их совместимости с информационными технологиями и техническими средствами, применяемыми в Системе, функций безопасности этих средств и особенностей их реализации, наличия гарантийной и (или) технической поддержки СрЗИ, а также уровня защищенности ПДн.

3.2.1. Общий состав средств защиты информации

В СЗИ Системы будут применяться следующие виды СрЗИ:

- *СрЗИ от НСД;*
- *средства антивирусной защиты;*
- *средства межсетевого экранирования;*
- *средства защиты каналов связи (СКЗИ);*
- *средства обнаружения вторжений;*
- *средства анализа защищенности.*

3.2.2. Средства защиты информации от несанкционированного доступа

Secret Net Studio, разработки и производства ООО "Код Безопасности", обеспечивает реализацию ИАФ, УПД, ЗНИ в Системе.

На базе Secret Net Studio будут функционировать все серверы и АРМ, входящие в состав защищенного сегмента сети Системы.

Централизованное управление Secret Net Studio будет осуществляться администратором безопасности Системы на сервере безопасности.

3.2.3. Средства антивирусной защиты

САВЗ Kaspersky Endpoint Security и Kaspersky Security Center, разработки и производства АО "Лаборатория Касперского", обеспечивает реализацию мер по АВЗ в Системе.

Клиентская часть Kaspersky Endpoint Security устанавливается на все АРМ Системы.

Kaspersky Endpoint Security на серверах и АРМ Системы будет функционировать в режиме централизованного управления с помощью Kaspersky Security Center, развернутого на сервере безопасности.

На сервер безопасности с сетевых ресурсов разработчика в автоматическом режиме загружаются обновленные базы и модули программы, которые впоследствии централизованно распространяются на серверы и АРМ Системы.

Администратор безопасности информации настраивает на сервере безопасности общую политику антивирусной защиты компонентов Системы.

Администратор безопасности информации осуществляет периодический контроль работоспособности обновлений баз САВЗ Системы, мониторинг наличия вирусных заражений и реагирование на них.

3.2.4. Средства межсетевого экранирования

Средства межсетевого экранирования осуществляют управление информационными потоками в Системе путем управления доступом субъектов доступа к объектам доступа.

Средства межсетевого экранирования будут реализованы в Системе на базе СрЗИ разработки и производства:

а) ООО "Код безопасности":

– АПКШ "Континент" 3.9. Отказоустойчивый (HA) кластер 2-х КШ Сервера Доступа. Платформа IPCR3000;

б) АО "Позитив Текнолоджис":

– PT AF разработки и производства "Позитив Текнолоджис".

Кластер МЭ АПКШ Континент будет установлен на периметре распределенных компонентов Системы и будет осуществлять контроль всех внешних и внутренних информационных потоков на сетевом уровне, в том числе на периметре Системы, между компонентами Системы, а также при взаимодействии Системы с иными ИС.

Управление кластером МЭ АПКШ Континент будет осуществляться ЦУС Континент. Управление ЦУС Континент будет осуществляться администратором безопасности информации.

PT AF будет установлен на границе Системы и будет обеспечивать межсетевое экранирование уровня веб-приложений для компонентов Системы, обслуживающих сайты, веб-службы и веб-приложения.

Управление PT AF будет осуществляться администратором безопасности информации.

3.2.5. Средства защиты каналов связи

Средства защиты каналов связи, разработки и производства ООО "Код безопасности", обеспечивают реализацию мер по ИАФ, УПД и ЗИС в Системе:

– СКЗИ на базе АПКШ "Континент" 3.9. ЦУС. Платформа IPC-R1000.

СКЗИ "Континент-АП" будет использоваться для обеспечения защиты информации при осуществлении информационного взаимодействия внешних пользователей с Системой.

Управление СКЗИ "Континент-АП" будет осуществляться администратором безопасности информации с помощью веб-интерфейса Сервера доступа АПКШ "Континент" 3.9.

СКЗИ на базе АПКШ "Континент" 3.9. будут использоваться для обеспечения конфиденциальности и целостности ИОД при ее передаче по каналам связи, выходящим за пределы контролируемой зоны в целях:

– организации защищенного взаимодействия Системы с иными ИС;

– организации защищенного взаимодействия территориально распределенных компонентов Системы.

3.2.6. Система обнаружения вторжений

Средства обнаружения вторжений разработки и производства ООО "Код безопасности" обеспечивают реализацию мер по СОВ в Системе:

– АПКШ "Континент" 3.9. Детектор Атак. Платформа IPC-R550.

СОВ будет обеспечивать обнаружение компьютерных атак (вторжений) на внешней границе Системы, осуществлять сбор и анализ информации об информационных потоках, передаваемых в рамках информационного взаимодействия Системы.

Управление компонентами СОВ (в том числе обновление баз сигнатур и баз решающих правил) будет осуществляться администратором безопасности информации.

3.2.7. Средства анализа защищенности

САЗ "Сканер-ВС", разработки и производства АО "НПО "Эшелон" обеспечивает реализацию мер по АУД в Системе.

САЗ "Сканер-ВС" будет использоваться в целях поиска уязвимостей в Системе.

Управление САЗ "Сканер-ВС" будет осуществляться администратором безопасности информации.

3.2.8. Места размещения элементов системы защиты информации Системы

Структурная схема комплекса СрЗИ Системы представлена в Приложении № 1 к настоящему документу.

Спецификация закупаемых СрЗИ представлена в Приложении № 2 к настоящему документу.

3.3 Меры защиты информации, подлежащие реализации в системе защиты информации Системы, и их выполнение

Меры по обеспечению безопасности Системы реализуются в соответствии с уровнем защищенности ПДн, актуальных УБИ, применяемых информационных технологий и особенностей функционирования Системы применительно ко всем объектам и субъектам доступа, в том числе в среде виртуализации.

В таблице 5 приведена реализация мер по обеспечению безопасности Системы.

Таблица 5 – Реализация мер по обеспечению безопасности Системы

Наименование меры	*Условное обозначение и номер меры*	*Реализация меры*
Идентификация и аутентификация пользователей и инициируемых ими процессов	*ИАФ.1*	*Применение Secret Net Studio.* *Применение встроенных в Secret Net Studio механизмов СрЗИ от НСД, позволит осуществлять управление идентификаторами и аутентификационной информацией исключительно из-под учетной записи администратора безопасности.* *Установленная конфигурация СрЗИ обеспечит блокирование рабочей станции и учетной записи пользователя при превышении предельного числа попыток ввода неверной информации идентификации/аутентификации. Дальнейшая разблокировка будет осуществляться администратором безопасности*
Управление идентификаторами	*ИАФ.3*	
Управление средствами аутентификации, в том числе хранение, выдача, инициализация, блокирование средств аутентификации и принятие мер в случае утраты и (или) компрометации средств аутентификации	*ИАФ.4*	
Защита обратной связи при вводе аутентификационной информации	*ИАФ.5*	*Применение встроенных механизмов СрЗИ от НСД в Secret Net Studio*
Идентификация и аутентификация пользователей, не являющихся работниками оператора (внешних пользователей)	*ИАФ.5*	*Применение встроенных механизмов СрЗИ от НСД в Secret Net Studio*
Управление (заведение, активация, блокирование и уничтожение) учетными записями пользователей, в том числе внешних пользователей	*УПД.1*	*Применение встроенных механизмов (аутентификации и идентификации) СрЗИ от НСД в Secret Net Studio*

Наименование меры	*Условное обозначение и номер меры*	*Реализация меры*
Реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа	*УПД.2*	*Применение встроенных механизмов (управление доступом) СрЗИ от НСД в Secret Net Studio* *Применение организационных мер, включающих разработку разрешительной системы (матрицы) доступа*
Управление (фильтрация, маршрутизация, контроль соединений, однонаправленная передача и иные способы управления) информационными потоками между устройствами, сегментами информационной системы, а также между информационными системами	*УПД.3*	*Применение подсистемы межсетевого экранирования на базе АПКШ "Континент" 3.9. в целях управления информационными потоками*
Разделение полномочий (ролей) пользователей, администраторов и лиц, обеспечивающих функционирование информационной системы	*УПД.4*	*Применение встроенных механизмов (контроль учетных записей) СрЗИ от НСД в Secret Net Studio* *Разделение полномочий будет осуществляться путем присвоения пользователям различных ролей (Пользователь, Администратор, Администратор безопасности)*
Назначение минимально необходимых прав и привилегий	*УПД.5*	
Ограничение неуспешных попыток входа в информационную систему (доступа к информационной системе)	*УПД.6*	*Применение встроенных механизмов (контроль и управление доступом) СрЗИ от НСД в Secret Net Studio.* *Установленная конфигурация СрЗИ обеспечит блокирование рабочей станции и учетной записи пользователя при превышении предельного числа попыток ввода неверной информации идентификации/ аутентификации. Дальнейшая разблокировка будет возможна администратором безопасности*
Блокирование сеанса доступа в информационную систему после установленного времени бездействия (неактивности) пользователя или по его запросу	*УПД.10*	*Применение встроенных механизмов (контроль и управление доступом) СрЗИ от НСД в Secret Net Studio.* *Установленная конфигурация СрЗИ обеспечит блокирование рабочей станции и учетной записи пользователя при превышении установленного времени бездействия*
Разрешение (запрет) действий пользователей, разрешенных до идентификации и аутентификации	*УПД.11*	*Применение встроенных механизмов (контроль и управление доступом) СрЗИ от НСД в Secret Net Studio. Неавторизированные пользователи не будут иметь доступ к Системе до прохождения идентификации/аутентификации*
Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети	*УПД.13*	*Применение АПКШ "Континент" 3.9. в целях организации защищенного соединения между внешними пользователями и компонентами Системы*
Регламентация и контроль использования в информационной системе технологий беспроводного доступа	*УПД.14*	*Применение организационных мер, включающих разработку перечня лиц, предоставление технологий беспроводного доступа которым необходимо для выполнения установленных должностных обязанностей (функций).* *Применение встроенных механизмов (управление доступом) СрЗИ от НСД в Secret Net Studio.*
Управление взаимодействием с информационными системами	*УПД.16*	*Применение АПКШ "Континент" 3.9. в целях организации защищенного соединения между внешними ИС и компонентами Системы*

Наименование меры	*Условное обозначение и номер меры*	*Реализация меры*
сторонних организаций (внешние информационные системы)		
Уничтожение (стирание) или обезличивание персональных данных на машинных носителях при их передаче между пользователями, в сторонние организации для ремонта или утилизации, а также контроль уничтожения (стирания) или обезличивания	*ЗНИ.8*	*Применение организационных мер, включающих разработанную инструкцию по учету и использованию машинных носителей информации, содержащей описание процедуры уничтожения (стирания) информации на машинных носителях*
Определение событий безопасности, подлежащих регистрации, и сроков их хранения	*РСБ.1*	*Применение встроенных механизмов СрЗИ от НСД в Secret Net Studio.* *Состав и содержание информации о событиях безопасности определяется конфигурацией Secret Net Studio.* *Доступ к материалам регистрации и учета событий безопасности предоставляется исключительно для учетной записи Администратора безопасности.* *Управление конфигурацией подсистемы регистрации и учета событий безопасности осуществляется исключительно Администратором безопасности*
Определение состава и содержания информации о событиях безопасности, подлежащих регистрации	*РСБ.2*	
Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения	*РСБ.3*	
Защита информации о событиях безопасности	*РСБ.7*	
Реализация антивирусной защиты	*АВЗ.1*	*Применение сертифицированных Kaspersky Endpoint Security и Kaspersky Security Center для централизованного управления*
Обновление базы данных признаков вредоносных компьютерных программ (вирусов)	*АВЗ.2*	
Обнаружение вторжений	*СОВ.1*	*Применение АПКШ "Континент" версии 3.9 (сигнатурные и эвристические способы обнаружения вторжений).* *Обновление базы решающих правил средства обнаружения и предотвращения компьютерных атак АПКШ "Континент" версии 3.9 из доверенных источников*
Обновление базы решающих правил	*СОВ.2*	
Выявление, анализ уязвимостей информационной системы и оперативное устранение вновь выявленных уязвимостей	*АНЗ.1*	*Применение САЗ "Сканер-ВС"*
Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации	*АНЗ.2*	*Применение организационных мер, включающих разработку инструкции по установке, модификации и техническому обслуживанию ПО и аппаратных средств.*
Контроль работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации	*АНЗ.3*	*Осуществление предварительного контроля правильности функционирования применяемого ПО и СрЗИ на тестовых стендах.* *Применение сертифицированных СрЗИ, осуществляющих самотестирование в автоматическом режиме, при старте аппаратных компонент*
Контроль состава технических средств, программного обеспечения и средств защиты информации	*АНЗ.4*	*Применение встроенных механизмов СрЗИ от НСД в Secret Net Studio.* *Применение организационных мер, включающих определение обязанностей по осуществлению*

Наименование меры	*Условное обозначение и номер меры*	*Реализация меры*
		контроля аппаратного состава Системы, ответственными лицами
Реализация и управление антивирусной защитой в виртуальной инфраструктуре	*ЗСВ.9*	*Применение сертифицированного САВЗ Kaspersky Endpoint Security*
Контроль и управление физическим доступом к техническим средствам, средствам защиты информации, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены, исключающие несанкционированный физический доступ к средствам обработки информации, средствам защиты информации и средствам обеспечения функционирования информационной системы, в помещения и сооружения, в которых они установлены	*ЗТС.3*	*Применение системы контроля и управления доступом для доступа на территорию, где располагаются компоненты Системы.* *Применение технических средств охранной сигнализации.* *Контроль физического доступа на основании утвержденного порядка и списка доступа в помещения, в которых осуществляется обработка и хранение ИОД*
Размещение устройств вывода (отображения) информации, исключающее ее несанкционированный просмотр	*ЗТС.4*	*Применение организационных мер, в том числе размещение мониторов АРМ, исключающее несанкционированный просмотр информации.* *Применение встроенных механизмов (контроль и управление доступом) СрЗИ от НСД в Secret Net Studio для блокировки рабочей станции при длительном бездействии*
Обеспечение защиты ПДн от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы контролируемой зоны, в том числе беспроводным каналам связи	*ЗИС.3*	*Применение АПКШ "Континент" 3.9. в целях организации защищенного соединения во всех сегментах информационного взаимодействия*
Защита беспроводных соединений, применяемых в информационной системе	*ЗИС.20*	*Применение организационных мер, включающих разработку перечня лиц, предоставление технологий беспроводного доступа которым необходимо для выполнения установленных должностных обязанностей (функций).* *Применение встроенных механизмов (контроль и управление доступом) СрЗИ от НСД в Secret Net Studio для предоставления доступа к параметрам настройки беспроводных соединений только администраторам безопасности, а также для управления идентификаторами и аутентификационной информацией исключительно из-под учетной записи администратора безопасности исключительно из-под учетной записи администратора безопасности.* *Применение организационных мер, включая регламентацию применения беспроводных соединений*

Наименование меры	*Условное обозначение и номер меры*	*Реализация меры*
Определение лиц, которым разрешены действия по внесению изменений в конфигурацию информационной системы и СЗИ	*УКФ.1*	*Применение организационных мер, включая разработку списка лиц, которым разрешены действия по внесению изменений в конфигурацию информационной системы и СЗИ*
Управление изменениями конфигурации информационной системы и системы защиты персональных данных	*УКФ.2*	*Применение встроенных механизмов (контроль учетных записей) СрЗИ от НСД в Secret Net Studio.* *Разделение полномочий путем присвоения пользователям различных ролей (Пользователь, Администратор, Администратор безопасности)*
Анализ потенциального воздействия планируемых изменений в конфигурации информационной системы и системы защиты персональных данных на обеспечение защиты персональных данных и согласование изменений в конфигурации информационной системы с должностным лицом (работником), ответственным за обеспечение безопасности персональных данных	*УКФ.3*	*Организационные меры, включающие разработанную и поддерживаемую в актуальном состоянии Модель угроз Системы (анализ потенциального воздействия планируемых изменений в конфигурации Системы и ее СЗИ на обеспечение защиты информации), а также согласование изменений в конфигурации Системы с должностным лицом (работником), ответственным за обеспечение безопасности персональных данных*
Документирование информации (данных) об изменениях в конфигурации информационной системы и системы защиты персональных данных	*УКФ.4*	*Организационные меры, включающие разработанные и поддерживаемые в актуальном состоянии описание настроек СрЗИ Системы и технический паспорт Системы*

3.4 Реализация мер по нейтрализации актуальных угроз безопасности информации

Меры по нейтрализации актуальных УБИ Системы, определенных в Модели угроз, приведены в таблице 6 (идентификаторы угроз даны согласно банку данных угроз безопасности информации ФСТЭК России https://bdu.fstec.ru (далее – БДУ ФСТЭК России)).

Таблица 6 – Меры по нейтрализации актуальных УБИ

№ п/п	*Идентификатор угрозы в БДУ ФСТЭК России*	*Наименование УБИ*	*Меры, направленные на нейтрализацию угроз*
1.	*004*	*Угроза аппаратного сброса пароля BIOS*	*Физическая охрана помещений с расположенными в них компонентами Системы в нерабочее время. Использование системы контроля и управления доступом. Опечатывание корпусов системных блоков АРМ и серверов. Обслуживание и обновление ПО, в том числе ПО BIOS/UEFI только системными администраторами*
2.	*006*	*Угроза внедрения кода или данных*	*Применение для АРМ и серверов сертифицированных средств антивирусной защиты "Kaspersky Endpoint Security", с регулярным обновлением базы данных вредоносных компьютерных программ (вирусов) исключительно из официальных источников*
3.	*008*	*Угроза восстановления и/или повторного использования аутентификационной информации*	*Эксплуатация встроенных механизмов (контроля и управления доступом) СрЗИ от НСД в Secret Net Studio*
4.	*012*	*Угроза деструктивного изменения*	*Эксплуатация встроенных механизмов (контроль целостности) СрЗИ от НСД в Secret Net Studio*

№ п/п	Идентификатор угрозы в БДУ ФСТЭК России	Наименование УБИ	Меры, направленные на нейтрализацию угроз
		конфигурации/среды окружения программ	
5.	013	Угроза деструктивного использования декларированного функционала BIOS	Ограничение прав пользователей по доступу к BIOS за счет парольной защиты доступа. Опечатывание корпусов системных блоков АРМ и серверов
6.	015	Угроза доступа к защищаемым файлам с использованием обходного пути	Эксплуатация встроенных механизмов (контроля и управления доступом) СрЗИ от НСД в Secret Net Studio
7.	018	Угроза загрузки нештатной операционной системы	Ограничение прав внутренних пользователей по доступу к BIOS за счет парольной защиты доступа. Опечатывание корпусов системных блоков АРМ и серверов
8.	084	Угроза НСД к системе хранения данных из виртуальной и (или) физической сети	Защита периметра и ИС, ее сегментирование, а также реализация управления сетевыми потоками функциями установленного на границе каждого территориально распределенного компонента Системы сертифицированного АПКШ "Континент" версии 3.9 (межсетевой экран, авторизация соединений, шифрованный канал, имитовставка, NAT). Физическая охрана помещений с расположенными в них компонентами Системы в нерабочее время. Использование системы контроля и управления доступом
9.	088	Угроза несанкционированного копирования защищаемой информации	Эксплуатация механизмов контроля учетных записей пользователей, контроля носителей информации и контроля и управления доступом в Secret Net Studio
10.	089	Угроза несанкционированного редактирования реестра	
11.	090	Угроза несанкционированного создания учетной записи пользователя	
12.	091	Угроза несанкционированного удаления защищаемой информации	

3.5 Сертификаты соответствия требованиям безопасности информации применяемых средств защиты информации

Сведения о сертификатах СрЗИ, используемых в СЗИ Системы, приведены в таблице 7.

Таблица 7 – Сертификаты ФСТЭК России применяемых СрЗИ

№ п/п	Наименование СрЗИ	Номер сертификата соответствия, срок действия
1.	Secret Net Studio	Сертификат соответствия ФСТЭК России № 3745 действителен до 16 мая 2030 г.
2.	Kaspersky Endpoint Security	Сертификат соответствия ФСТЭК России № 2534 действителен до 27 декабря 2030 г.
3.	Kaspersky Security Center	Сертификат соответствия ФСТЭК России № 3155 действителен до 6 мая 2030 г.

№ п/п	*Наименование СрЗИ*	*Номер сертификата соответствия, срок действия*
4.	*"Сканер-ВС"*	*Сертификат соответствия ФСТЭК России № 2204 действителен до 11 ноября 2029 г.*
5.	*АПКШ Континент*	*Сертификат соответствия ФСТЭК России № 4145 действителен до 17 июля 2029 г.* *Сертификат соответствия ФСБ России № СФ/124-4804 действителен до 15 марта 2027 г.*
6.	*Континент-АП*	*Сертификат соответствия ФСБ России № СФ/124-4844 действителен до 8 декабря 2030 г.*
7.	*Программный комплекс "Кибер Бэкап"*	*Сертификат соответствия ФСТЭК России № 4337 действителен до 11 декабря 2030 г.*

3.6 Решение по организационному обеспечению

Для выполнения требований к организационному обеспечению, установленных в п. 4.3.7 Технического задания, в Системе осуществляется:

– назначение структурного подразделения или должностного лица, ответственного за защиту информации (обеспечение безопасности) Системы;

– разработка (актуализация) и утверждение перечня лиц, допущенных к обработке ИОД Системы, для выполнения ими функциональных (служебных) обязанностей (список лиц группы сопровождения и администрирования Системы, разрешительная система доступа);

– назначение администратора безопасности информации, ответственного за администрирование СрЗИ Системы, определение его обязанностей;

– обеспечение сохранности носителей ИОД, в том числе машинных носителей информации и персональных идентификаторов;

– организация режима обеспечения безопасности помещений, в которых размещена Система, препятствующего возможности неконтролируемого проникновения или пребывания в этих помещениях лиц, не имеющих права доступа в эти помещения

3.7 Решение по численности и квалификации персонала системы защиты информации

В целях реализации требований к численности и квалификации персонала СЗИ Системы, установленных в п. 4.4.1 Технического задания, определено:

а) численность персонала СЗИ Системы определяется исходя из необходимости обеспечения работы всех подсистем и программно-технических средств, входящих в состав Системы;

б) работники, выполняющие в Системе функции администраторов безопасности информации, осуществляют обслуживание и эксплуатацию комплекса СрЗИ Системы по рабочим дням в рабочее время, с возможностью выхода в нерабочее время или в выходные дни для проведения сервисного обслуживания, ремонта или восстановления работоспособности СЗИ Системы;

в) персонал СЗИ Системы должен иметь следующую квалификацию:

– наличие навыков администрирования программных и программно-аппаратных средств, входящих в состав СЗИ Системы;

– знание руководящих и нормативных методических документов ФСТЭК России и ФСБ России по вопросам обеспечения защиты информации, обрабатываемой в ИСПДн, включая вопросы криптографической защиты информации;

– *знание порядка эксплуатации СрЗИ, применяемых в Системе, и технологические особенности их функционирования согласно документации производителя СрЗИ.*

3.8 Обеспечение надежности

Комплекс СрЗИ Системы будет функционировать в круглосуточном режиме, за исключением перерывов на профилактику и перенастройку Системы.

Предусмотрено, что для обеспечения устойчивости к отказам электроснабжения критически важные элементы Системы (технические средства серверов Системы) будут подключаться к электросети через источники бесперебойного питания.

Предусмотрено, что комплекс СрЗИ Системы будет сохранять работоспособность и обеспечивать восстановление своих функций после устранения сбоев и корректного перезапуска ПО и аппаратного обеспечения при возникновении следующих нештатных ситуаций:

– *при сбоях в системе электроснабжения аппаратной части, приводящих к перезагрузке ОС, восстановление осуществляется после перезапуска ОС;*

– *при ошибках в работе аппаратных средств восстановление обеспечивается встроенным ПО аппаратных средств либо оперативной заменой неисправного оборудования;*

– *при ошибках, связанных с ПО (ОС и драйверы устройств), восстановление работоспособности возлагается на ОС.*

Предусмотрено, что для обеспечения возможности полного восстановления работоспособности комплекса СрЗИ Системы будет обеспечиваться регулярное резервное копирование конфигураций компонентов СЗИ Системы сертифицированными средствами резервного копирования.

3.9 Обеспечение безопасности

В целях реализации требований по безопасности, указанных в п. 4.4.4 Технического задания, предусмотрено:

– *для всех технических (аппаратных) средств СЗИ Системы обеспечивается радиоэлектронная безопасность при монтаже, наладке, эксплуатации, обслуживании и ремонте в соответствии с ГОСТ-12.1.006;*

– *для всех технических (аппаратных) средств СЗИ Системы обеспечивается соответствие уровням вибрационных, шумовых и акустических нагрузок в соответствие с ГОСТ 12.1.003;*

– *для всех технических (аппаратных) средств СЗИ Системы обеспечивается соответствие эргономическим и гигиеническим требованиям в соответствии с нормами СН-21571.*

3.10 Решения по эксплуатации, техническому обслуживанию, ремонту и хранению компонентов

В целях реализации требований, указанных в п. 4.4.6 Технического задания:

– *СЗИ Системы функционирует в тех же режимах, что и защищаемая ею Система;*

– *эксплуатация, техническое обслуживание, ремонт и хранение компонентов СЗИ Системы осуществляются на основе эксплуатационной документации на программные, аппаратные и программно-аппаратные средства, входящие в состав СЗИ Системы.*

3.11 Обеспечение сохранности информации при авариях

В целях реализации требований к сохранности информации при авариях, установленных в п. 4.4.7 Технического задания, в Системе используются средства и применяются технические решения, обеспечивающие сохранность информации и восстановления функционирования СЗИ Системы без потери информации в аварийных ситуациях.

Сохранность информации при авариях обеспечивается за счет резервного копирования информации, обрабатываемой в Системе, в том числе за счет подключения компонентов СЗИ Системы к средствам обеспечения бесперебойного электропитания.

4. Мероприятия по подготовке к внедрению системы защиты информации

4.1. Организационные меры по обеспечению безопасности Системы

В целях организации нормативно-методического обеспечения безопасности информации в Системе будет разработана (актуализирована) и утверждена следующая организационно-распорядительная и эксплуатационная документация (при необходимости):

- *приказ об утверждении ответственных лиц;*
- *технический паспорт Системы;*
- *описание настроек СрЗИ;*
- *акт установки и настройки СрЗИ;*
- *положение (приказ) о режиме обеспечения безопасности помещений с ИСПДн (с инструкцией о порядке доступа в помещения ИСПДн, перечнем лиц, имеющих право доступа в помещения ИСПДн);*
- *список лиц, которым разрешены, действия по внесению изменений в конфигурацию Системы;*
- *перечень лиц, доступ которых к персональным данным, обрабатываемым в информационной системе, необходим для выполнения ими служебных (трудовых) обязанностей;*
- *разрешительная система (матрица) доступа;*
- *сборник инструкций по обеспечению информационной безопасности;*
- *план внутренних проверок состояния и защиты персональных данных*
- *журналы учета машинных носителей информации.*

По окончании работ по внедрению СЗИ Системы будет проведена оценка соответствия Системы требованиям о защите информации.

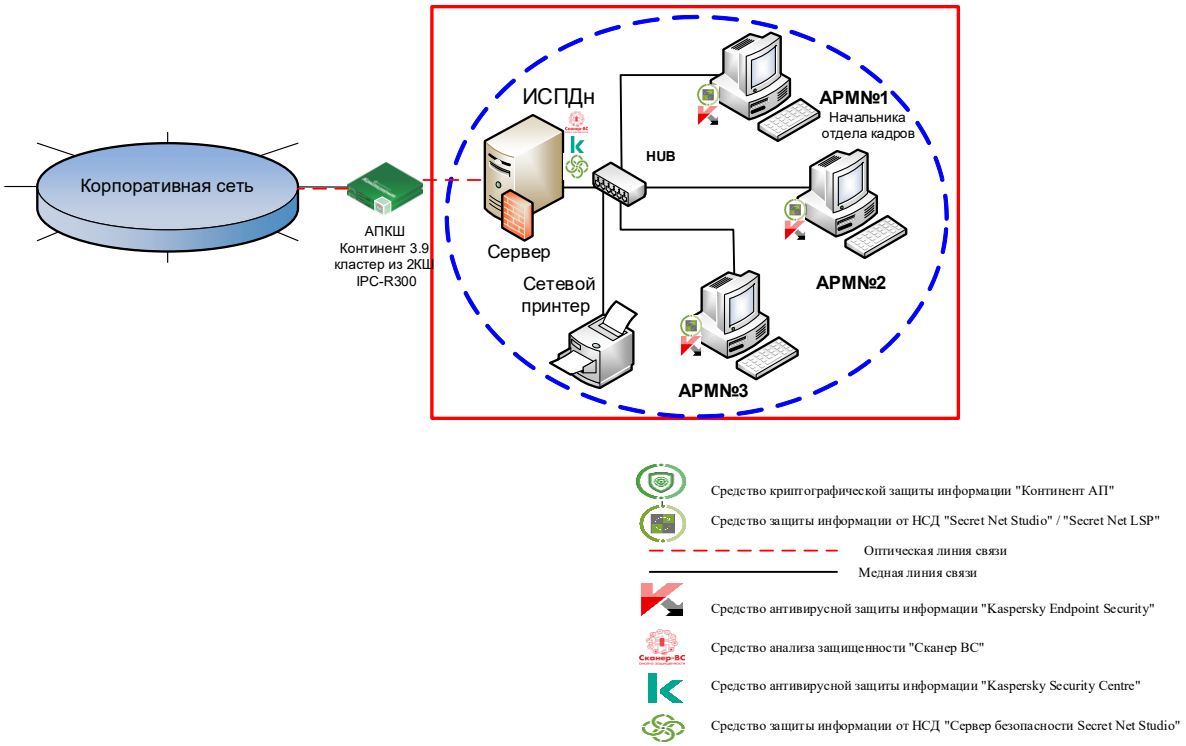
По результатам проведения оценки соответствия Системы требованиям о защите информации будут разработаны следующие документы:

- *протокол оценки соответствия Системы требованиям о защите информации;*

заключение по результатам оценки соответствия Системы требованиям о защите информации.

Приложение № 1
к Пояснительной записке
к техническому проекту на создание системы защиты информации

Структурная схема комплекса СрЗИ Системы



Приложение № 2
к Пояснительной записке
к техническому проекту на создание системы защиты информации

Спецификация закупаемых СрЗИ

№ п/п	Наименование	Количество
1.	АПКШ "Континент" 3.9. ЦУС. Платформа IPC-R1000. КС3	1
2.	АПКШ "Континент" 3.9. Детектор Атак. Платформа IPC-R50	1
3.	Сертифицированный ФСТЭК России дистрибутив Kaspersky Стандартный Certified Media Pack Russian Edition	1
4.	СКЗИ "Континент-АП"	1
5.	Средство защиты информации от НСД "Secret Net Studio" / "Secret Net LSP"	3
6.	Программный комплекс "Кибер Бэкап"	1
7.	Средство анализа защищенности "Сканер ВС"	1